

Identity Governance Validation Engine

Project Portfolio — IAM Engineering

Microsoft Azure / Entra ID / PowerShell

March 2026

A. Executive Summary

Enterprise identity environments accumulate risk invisibly. Employees change roles and retain old access. Contractors end up in management-tier groups. Azure subscriptions accumulate Owner assignments that were supposed to be temporary. Accounts remain active for weeks after people leave. None of this surfaces in routine reports because cloud platforms record state — they do not evaluate it against any standard.

Periodic audits catch some of this. But a quarterly spreadsheet review has a fundamental limitation: it tells you what the state was on the day someone ran the export. The day after the export, a new direct Owner assignment can appear and go undetected for three months.

I designed and built the Identity Governance Validation Engine to solve this. It is a compliance and risk assessment system for Microsoft Azure and Entra ID that evaluates every identity in the tenant on demand against a configurable rule set and produces a structured, machine-readable output that automated workflows can act on immediately.

The engine introduces continuous risk validation. Rather than a point-in-time audit, it runs as often as needed — daily drift scans, pre-provisioning gates before any new access is granted, weekly full compliance sweeps. Every run produces the same format of output. Risk trends are tracked across runs.

48 Identities evaluated	26 Active rules across 6 categories	138 Findings produced, first stable run	7.2–80.6 Risk score range (normalised 0–100)
---	---	---	--

B. Core Innovation

Most IAM tooling in the Azure ecosystem is either a monitoring dashboard (reactive) or a provisioning system (prescriptive). This engine sits between those two categories: it is an evaluation layer that can be called by either.

Lifecycle-Aware Validation

The engine understands identity lifecycle context, not just current state. A Contractor in a Manager-tier group is not just a policy violation — it is a specific lifecycle failure where employment type was not validated at provisioning time. The rule that fires (ENT-002) tells you not just that there is a problem but what kind of lifecycle event caused it, which makes remediation actionable rather than investigative.

Dual Classification Model

Most scoring systems produce a single number. This engine produces two independent outputs per identity, because compliance and risk answer different questions:

- ComplianceStatus (Compliant / NonCompliant / Blocking) is a binary gate for automated workflow decisions. A JML workflow needs a yes/no — can this identity be provisioned? Not a score.
- RiskScore (0–100 normalised) is a continuous signal for security triage and trend analysis. It answers: of all the identities that have issues, which ones need attention first?

Keeping these separate means an identity with an inactive account and a stale password (real operational issues) does not show as NonCompliant — it shows as Compliant with hygiene signals. This distinction matters when compliance statistics are reported to leadership.

Severity Inflation Control — Suppression Chain

A direct Owner assignment at subscription scope could naively fire five separate rules simultaneously. Without suppression, the same security fact inflates the risk score five times. I designed an explicit suppression hierarchy: the most specific rule suppresses the less specific ones. Owner assignment fires RBAC-003 (forbidden role), which suppresses RBAC-002 (broad scope) and RBAC-001 (direct assignment) for the same entity. The score reflects one finding, not five.

The suppression relationships are declared in the rules configuration file, not hardcoded in the evaluation logic. Adding a new suppression relationship requires a configuration change, not a code change.

Mode-Based Scanning

Mode	When Used	What It Evaluates
PreProvision	Before any new access is granted (Joiner, Mover events)	Single identity. Blocking rules only. Returns Pass/Fail in under 10 seconds. Zero Azure subscription scanning.
FullScan	Weekly compliance baseline, monthly audit reporting	All identities, all 26 rules, full RBAC scanning across all subscriptions. Produces CSV and JSON output.
DriftOnly	Daily lightweight check between FullScan runs	Structural rules only (RBAC, Architecture, Correlation). Detects new Owner assignments or group changes without a full evaluation.

Subscription-Agnostic by Default

The engine scans every Azure subscription the service account can see, not a pre-configured list. This was a deliberate design choice. An IAM risk in a subscription the IAM team does not know about is still a real risk. Restricting scope to known subscriptions would produce false confidence. Scope restriction is available as an opt-in parameter when a specific business unit boundary is a genuine operational requirement.

C. Real-World Scenarios

These are findings from the actual first stable run against a live tenant. They illustrate the kind of risk the engine surfaces and why it matters.

Scenario 1: Dormant Privileged Account with Owner Role

FINDING An account with no recorded sign-in (`LastSignInDateTime` null) holds Owner role directly assigned on two Azure subscriptions, has no MFA registered, and is a member of a privileged-tier group. RiskScore: 80.6. ComplianceStatus: Blocking.

Five separate rules fire on this identity: no MFA on a privileged account (HYG-004, blocking), Owner role directly assigned at subscription scope on two subscriptions (RBAC-003, blocking), privileged group member with Owner at subscription scope (CORR-001, blocking), never signed in but holds RBAC assignments (CORR-005), and the account holds both privileged and standard group membership simultaneously (ACCESS-003).

Business impact: An account that has never signed in holds direct Owner on two subscriptions. If compromised, an attacker has immediate unrestricted access to all resources in both subscriptions with no MFA barrier. This is the highest-risk finding category the engine detects.

Scenario 2: Contractor in Management Tier Group

FINDING 8 entities flagged by ENT-002: employment type not permitted for a privileged-tier group. Contractors and interns in groups designated as Manager or Manager/Staff tier. ComplianceStatus: Blocking.

The entitlement model in the engine configuration defines which employee types are permitted in which groups. Exec_Team and Finance_Managers are Manager-tier groups — only Full-time employees are permitted. When a Contractor is provisioned into either group, ENT-002 fires with blocking status.

Business impact: Contractors with manager-tier access have visibility into resources and data that their employment classification does not authorise. Depending on the group, this may include financial systems, HR data, or privileged Azure resource management.

Scenario 3: Sign-in Telemetry Failure Masking Real Risk

FINDING First production run: HYG-002 (inactive >180 days) fired on 43 of 48 identities. Not because accounts were inactive — because `LastSignInDateTime` was null for all users. Root cause: AuditLog.Read.All scope was missing from the Graph connection.

This scenario illustrates why documenting failure modes is as important as documenting the happy path. The engine was returning data that looked like a compliance problem but was actually a data collection gap. Without explicit documentation of the AuditLog.Read.All dependency and its failure behaviour, this would have appeared as a 0% compliant tenant and triggered remediation work on a false signal.

What the engine does: The HYG-002 rule includes a documented data dependency noting that null `LastSignInDateTime` fires the rule. The `signInActivity` capability probe in the collector detects whether the scope is available before the full user enumeration runs. This makes the failure detectable and the fix explicit.

Scenario 4: RBAC Sprawl Across Two Subscriptions

FINDING 22 direct Azure role assignments detected across 2 subscriptions (TotalDirectRBACAssignments in Summary). Policy requires group-based assignment. 6 assignments involve the forbidden Owner role directly assigned to users.

Direct role assignments bypass group-based access controls. A user with a direct Owner assignment is invisible to anyone reviewing group memberships. When the user leaves the organisation and their groups are revoked, the direct RBAC assignment persists — this is exactly the pattern that CORR-002 detects.

Business impact: Direct assignments are harder to audit, harder to revoke at scale, and more likely to persist after lifecycle events. The engine flags all 22 as RBAC-001 findings, with the 6 Owner assignments as RBAC-003 (blocking).

D. Design Philosophy

The architecture of this engine reflects a set of explicit principles. These are not preferences — they are decisions with trade-offs that were chosen deliberately.

Collectors Are Fact-Only

The identity and RBAC collectors do one thing: call an API, normalise the response, and return a structured snapshot. They contain no rule logic, no filtering based on findings, and no interpretation of what the data means. A bug in a collector is a data bug. A bug in a rule processor is a logic bug. These two failure modes are cleanly separated, which means they are independently testable and independently debuggable.

Deterministic Rule Processing

The same input always produces the same output. Rules are evaluated from a static configuration file. There is no randomness, no sampling, and no state carried between rule evaluations. This is a deliberate constraint — an audit-grade system must be reproducible. If a finding appears in one run and disappears in the next with no change to the underlying state, that is a bug, not expected behaviour.

Transparent Scoring

Every finding carries its weight explicitly. The risk score formula is documented and uses a fixed normalisation constant. An IAM engineer can look at any entity's findings, sum the weights, apply the formula, and arrive at the same RiskScore the engine produces. There is no black-box weighting, no machine learning model, no dynamic adjustment. Transparency is a feature in a compliance context — stakeholders need to be able to explain why a score changed.

API Scope Validation Awareness

The engine documents exactly what happens when each required API scope is missing. This is not standard practice — most tools simply fail or return empty results silently. The explicit failure mode documentation for `AuditLog.Read.All`, `UserAuthenticationMethod.Read.All`, and the Az module context came directly from production failures encountered during development. Each failure was diagnosed, documented as a known failure state, and given an explicit detection mechanism where possible.

Separation of Compliance and Hygiene

Hygiene signals (inactive accounts, stale passwords) are real risk indicators, but they are not compliance failures in the same category as a terminated employee with active group memberships. Conflating them inflated compliance statistics in early runs and made the output misleading. The decision to separate hygiene from the compliance gate — while keeping hygiene signals visible in the risk score — was one of the most significant design choices and required reworking the classification layer after the problem was observed in production.

E. What This Demonstrates

Capability	Evidence in This Project
Architectural separation of concerns	Five distinct layers (Collection, Schema, Evaluation, Classification, Reporting) with explicit contracts between them. No layer reaches across boundaries. Each layer is independently testable.
Cloud IAM domain knowledge	Practical understanding of Entra ID user attributes, group privilege classification, Azure RBAC scope hierarchy, employment lifecycle states, MFA registration APIs, and Graph scope requirements.
Risk modelling capability	Dual-model classification (ComplianceStatus + RiskScore). Suppression chain design to prevent severity inflation. Fixed normalisation against theoretical maximum for cross-tenant comparability.
Production constraint awareness	Documented failure modes for every API scope dependency. Explicit session expiry detection. signInActivity capability probe. Non-fatal vs fatal error classification. Graceful degradation on missing scopes.
Ability to design audit-grade systems	Deterministic output, reproducible findings, transparent scoring formula, stable RuleIds for downstream automation, ISO 8601 timestamps for SIEM ingestion, drift state for trend analysis.
Diagnosing real-world problems	Identified and fixed 0% compliance distribution caused by missing Graph scope. Identified double-fire on IDENT-003/004 for same data point. Identified RBAC-002/003 scope stacking. Each diagnosis required reading structured output, tracing to root cause in data or logic, and applying a targeted fix.

Project Limitations

This project was built and validated against a single tenant with 48 identities. The architecture is designed to scale, but large-tenant performance has not been tested. The following limitations apply:

- No retry logic for Graph throttling (429 responses). Large tenants may need retry handling added to collectors.
- Sequential subscription enumeration. Organisations with many subscriptions will experience linear performance degradation.
- MFA resolution (-ResolveMfa) requires one Graph call per user. At scale this adds significant latency and should be scheduled separately from frequent drift scans.
- Entra ID directory roles and PIM eligibility are not evaluated. A Global Administrator assigned through PIM is invisible to the current RBAC rules.
- The entitlement model (group definitions and tier mappings) is currently manual configuration. It does not auto-discover groups or infer tier from Entra ID properties.

NEXT PHASE The JML workflow layer that calls this engine at provisioning time is under active development. When complete, the PreProvision mode will serve as a gate in an automated Joiner/Mover/Leaver pipeline — blocking provisioning when identity state does not meet policy before any access is granted.